

the parties, and vice versa. There are primarily two kinds of CAs:

- Private CAs that are internal to an organisation.
- Public CAs, which are third party such as IdenTrust, Digicert, GobaSign, etc.

CAs offer a range of services, such as:

- Key generation: Creating a secure public and private key pair for the chosen cipher, algorithm and strength.
- Issuance of certificate: A user submits a request to the CA, giving its public key and its details. The CA verifies the user and provides a certificate.
- Validation of the certificate.
- Validation of the parties applying for the certificate.
- Establishing trust between users, government, and organisations.
- Managing the servers that store the certificates and private keys.
- Life cycle management of keys and certificates.
- Revoking invalid certificates due to their expiry; if the primary key is compromised, it is revoked from users.
- Renewal and issuance of new certificates generated either with the same key or new key. Usually, when the old key is not long enough or risky, a new key is used. In this case, the CA checks if any data encrypted with the old key needs to be decrypted and encrypted back with the new key.

## Certificate practice statement (CSP)

CSP is the legal document a CA creates and publishes for users. It includes:

- Identification of the CA
- Types of certificates issued
- Applicable certificate policies
- Procedures for issuing, renewing and revoking certificates
- Security controls maintained by the CA

The certificate policy lays out the rules applied to an issued certificate.

## PKI trust models

Trust model is an important concept in PKI. It helps us see how users and different CAs are able to trust each other.

**Single CA:** Here, only a single CA serves requests to the users and issues certificates. One issue with this is single point of failure. If the CA is compromised, the entire PKI collapses. This model is good only for small organisations.

**Hierarchical CA:** In this tree model, the root CA issues certificates to the next level CA called the intermediate

CA. The good part is that each intermediate CA can have its own policies for issuing certificates and acts as a load balancer.

The intermediate CA can issue certificates, referred to as trust hierarchy. And each intermediate CA can be traced back to the root CA, which is called certificate chaining or chain of trust. For example:

- The root certificate verifies certificate A.
- Certificate A verifies certificate B.
- Certificate B verifies certificate C.

But the risk of single point of failure remains in this model too, as the root CA is the primary CA. Also, cross-

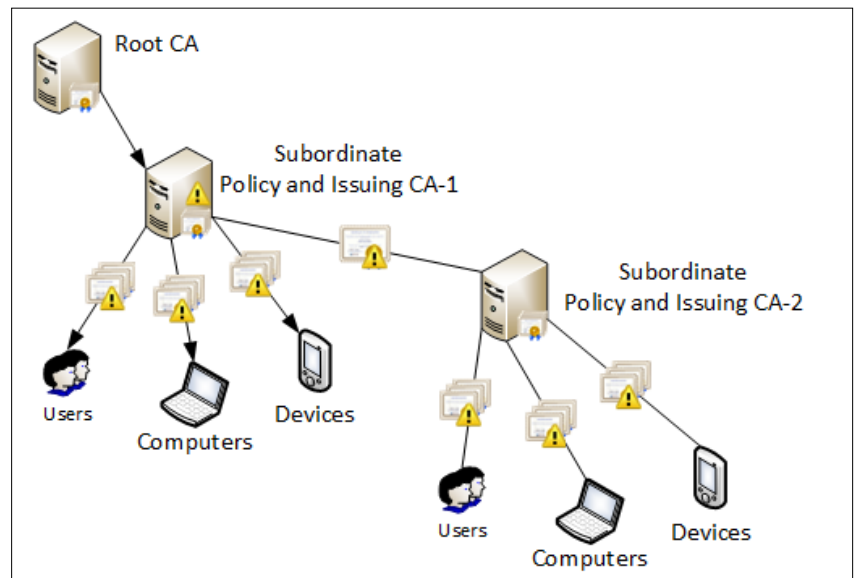


Figure 1: PKI trust models (Credits: <https://www.sysadmins.lv/content/images/pages/1998/hierarchy.png>)

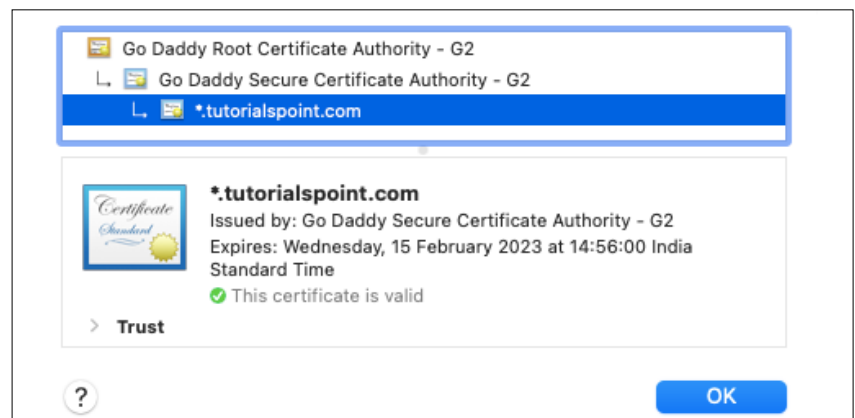


Figure 2: Hierarchical CAs